

Informe de Auditoría de Seguridad 2025

Resultados de auditoría técnica y recomendaciones de mitigación

Organización	Blandskron SpA
Autor	Equipo de Auditoría
Fecha	11/08/2025
Versión	1.0
Clasificación	Confidencial

Resumen Ejecutivo

Este informe presenta los hallazgos clave y las recomendaciones derivadas de la auditoría de seguridad realizada a la aplicación web institucional. El objetivo principal fue identificar vulnerabilidades críticas, evaluar su impacto y proponer medidas de mitigación. La estructura y diseño se han adaptado para ofrecer una experiencia clara, gráfica y profesional.

Descripción General del Entorno

- Superficie de ataque externa e interna.
- API y endpoints críticos.
- Configuraciones de servidores y bases de datos.
- Controles de autenticación y autorización.
- Respuesta ante errores y manejo de excepciones.

Principales Vulnerabilidades Detectadas

Hallazgo	Impacto	Criticidad	Recomendación
Uso de credenciales por defecto	Acceso administrativo no autorizado, comprometer la integridad de los datos.	Alta	Reemplazar credenciales predeterminadas por valores únicos y complejos.
Exposición de trazas internas	Filtración de rutas y lógica interna, facilitando ataques dirigidos.	Medio	Configurar manejo de errores genérico, ocultando detalles técnicos.
API sin autenticación	Acceso libre a datos sensibles, incumplimiento de requisitos de seguridad.	Alta	Implementar autenticación robusta (JWT o OAuth2).

Análisis Detallado: API sin Autenticación

Descripción:	Endpoint público expone datos personales sin requerir autenticación.
Herramientas:	Postman v10, cURL.
Metodología:	Se realizó una solicitud GET a /api/v1/clientes sin credenciales, obteniendo datos sensibles con éxito.

Evidencia

```
GET /api/v1/clientes HTTP/1.1
Host: ejemplo.gov
HTTP/1.1 200 OK
Content-Type: application/json
[ { "id": 1, "nombre": "Juan Pérez", "email": "juan.perez@ejemplo.gov" } ]
```

Recomendaciones

- Autenticación obligatoria para todos los endpoints críticos.
- Control de acceso granular por roles o atributos.
- Monitorización con alertas de acceso no autorizado.

Conclusiones

Las vulnerabilidades de criticidad alta representan riesgos inmediatos que deben abordarse de forma prioritaria. La implementación de controles de seguridad robustos, junto con auditorías periódicas y monitoreo continuo, es esencial para garantizar la resiliencia del entorno.

Recomendaciones Finales

- Fortalecer la identidad digital: MFA resistente al phishing, revisiones de cuentas y accesos just-in-time.
- Aumentar la visibilidad entre dominios: Integración de SIEM/XDR para correlación de eventos.
- Defender la nube como infraestructura central: CNAPP con CDR para proteger aplicaciones nativas en la nube.
- Priorizar vulnerabilidades: Parches regulares y gestión proactiva de riesgos.
- Conocer al adversario: Inteligencia de amenazas y ejercicios de simulación para anticipar ataques.

Informe de Auditoría de Seguridad 2025

Resultados de auditoría técnica y recomendaciones de mitigación

Organización	Blandskron SpA
Autor	Equipo de Auditoría
Fecha	11/08/2025
Versión	1.0
Clasificación	Confidencial

Resumen Ejecutivo

Este informe presenta los hallazgos clave y las recomendaciones derivadas de la auditoría de seguridad realizada a la aplicación web institucional. El objetivo principal fue identificar vulnerabilidades críticas, evaluar su impacto y proponer medidas de mitigación. La estructura y diseño se han adaptado para ofrecer una experiencia clara, gráfica y profesional.

Descripción General del Entorno

- Superficie de ataque externa e interna.
- API y endpoints críticos.
- Configuraciones de servidores y bases de datos.
- Controles de autenticación y autorización.
- Respuesta ante errores y manejo de excepciones.

Principales Vulnerabilidades Detectadas

Hallazgo	Impacto	Criticidad	Recomendación
Uso de credenciales por defecto	Acceso administrativo no autorizado, comprometer la integridad de los datos.	Alta	Reemplazar credenciales predeterminadas por valores únicos y complejos.
Exposición de trazas internas	Filtración de rutas y lógica interna, facilitando ataques dirigidos.	Medio	Configurar manejo de errores genérico, ocultando detalles técnicos.
API sin autenticación	Acceso libre a datos sensibles, incumplimiento normativo.	Alta	Implementar autenticación robusta (JWT o OAuth2).

Análisis Detallado: API sin Autenticación

Descripción:	Endpoint público expone datos personales sin requerir autenticación.
Herramientas:	Postman v10, cURL.
Metodología:	Se realizó una solicitud GET a /api/v1/clientes sin credenciales, obteniendo datos sensibles con éxito.

Evidencia

```
GET /api/v1/clientes HTTP/1.1
Host: ejemplo.gov
HTTP/1.1 200 OK
Content-Type: application/json
[ { "id": 1, "nombre": "Juan Pérez", "email": "juan.perez@ejemplo.gov" } ]
```

Recomendaciones

- Autenticación obligatoria para todos los endpoints críticos.
- Control de acceso granular por roles o atributos.
- Monitorización con alertas de acceso no autorizado.

Conclusiones

Las vulnerabilidades de criticidad alta representan riesgos inmediatos que deben abordarse de forma prioritaria. La implementación de controles de seguridad robustos, junto con auditorías periódicas y monitoreo continuo, es esencial para garantizar la resiliencia del entorno.

Recomendaciones Finales

- Fortalecer la identidad digital: MFA resistente al phishing, revisiones de cuentas y accesos just-in-time.
- Aumentar la visibilidad entre dominios: Integración de SIEM/XDR para correlación de eventos.
- Defender la nube como infraestructura central: CNAPP con CDR para proteger aplicaciones nativas en la nube.
- Priorizar vulnerabilidades: Parches regulares y gestión proactiva de riesgos.
- Conocer al adversario: Inteligencia de amenazas y ejercicios de simulación para anticipar ataques.